Gimel Foundation

Gimel Foundation gGmbH i.G.
GiFo-Request for Comments: 0171
Obsoletes: -
Category: Informational
Version: 0.5 (Draft – Under Vendor Review)

G. Wehberg and the Architecture Working Group of Gimel Foundation

19. October 2026

Agentic Commerce and Payment Authorization – Evaluation

Abstract

Agentic commerce combines several distinct functions: shopping and checkout orchestration, agent recognition, delegated authority, payment authorization and settlement. This RFC evaluates the publicly documented mechanisms that provide those functions, using a common evidence framework.

Scope: The main evaluation selects offerings positioned as agent-commerce or agent-payment solutions and applies the same nine criteria to all of them. As the **AP2** protocol (published September 2025) is currently the most present, its evaluation has been detailed as reference case. Additionally, the evaluation framework has been applied to **GAuth** (July 2025, patent pending) as an inherited authority core together with G-Commerce as commerce enforcement. These refers to GiFo-RFCs 0110, 0111, 0115, 0116, 0117, 0118, 0119 and 0170.

The assessment evaluates architectural mechanisms, not deployment tests, adoption or maturity. The evaluation assesses its named native mechanism and specified dependencies.

Bottom line, AP2 already specifies explicit consent, cryptographic delegation, open-to-closed mandate chains, deterministic constraint checks and cumulative recurring-payment budgets. It does not establish the complete independent authority and lifecycle guarantees (§4). GAuth + G-Commerce has full coverage of all evaluation criteria at the reviewed architectural boundary (§7). The other reviewed architectures establish narrower coverage.

Conclusion: The constructive implication is to combine, rather than conflate, principal authority, platform permission and payment execution. GiFo-RFC 0170 supplies a proposed integration contract and cookbooks.

Traditional payment and checkout interfaces are retained in Appendix D as potential CCPE-F integration substrates, with a complete GiFo-RFC 0170 cookbook crosswalk.

Status of This Memo

This document is published as a work-in-progress draft and is currently under review. Vendor and protocol descriptions are sourced from public entries, vendor product documentation, and other publicly available materials published by the vendors or protocol owners themselves. No characterization is original analysis without an attributed source. The evaluation framework (criteria + assessment) is the original value-add of this document; the descriptions are aggregated public material.

Corrections, clarifications, and additions from the vendors or protocol owners are actively solicited and will be incorporated into subsequent revisions.

This is a Gimel Foundation Informational document. It represents the current consensus of the Gimel Foundation community pending the vendor-review cycle. Information about the status of this document, any errata, and how to provide feedback may be obtained at https://gimelfoundation.com or https://github.com/Gimel-Foundation.

Legal notice

Copyright (c) 2026 Gimel Foundation and the persons identified as the document authors. All rights are reserved.

This document is subject to GiFo-RFC 0080 (Gimel Foundation Legal Provisions Relating to GiFo Documents), GiFo-RFC 0090 (Gimel Foundation Rights in Contributions), and GiFo-RFC 0100 (Gimel Foundation Intellectual Property Rights Policy) in effect on the date of publication of this document (see http://GimelFoundation.com or https://github.com/Gimel-Foundation). Please review these documents carefully, as they describe your rights and restrictions with respect to this document.

Trademark Notice. Product names, trademarks, and registered trademarks referenced in this document are the property of their respective owners and are used here for descriptive identification purposes only under nominative fair use principles. No endorsement, sponsorship, partnership, or affiliation is implied.

Notational Conventions

The key words "Must", "Must Not", "Required", "Shall", "Shall Not", "Should", "Should Not", "Recommended", "May", and "Optional" in the following specification are to be interpreted as described in IETF RFC 2119.

* * *

Table of Contents

1. Scope and method
2. Terminology and evaluation criteria
3. Landscape and cross-solution assessment
4. AP2 reference-case deep dive
5. Other mechanisms and practical comparison cases
6. G-Commerce under the same standard
7. Conclusions and correction process

Appendix A — Worked integration and cross-border examples
Appendix B — Sources and evidence boundaries
(Appendix C — Version tracking / Intentionally left blank for now)
Appendix D — Traditional payment and checkout substrates
Appendix E — Evaluation Summary

* * *

1. Scope and method

1.1 Search boundary

The evaluation applied in this RFC includes concrete offerings publicly positioned for agent commerce or agent payments. The inclusion basis is recorded in §§4.1–4.2 and sources A1–A4, B1–B11 and S1–S3: agent checkout, delegated payment, agent transactions or agent recognition at commerce boundaries. Inclusion does not establish any C1–C9 capability. A vendor name or generic payment API alone is insufficient. Traditional payment/checkout interfaces are retained in Appendix D; its crosswalk preserves all seven RFC 0170 cookbooks and the named expansion surfaces.

Evaluation rule: Apply C1–C9 to every selected candidate, including the reference architecture. Assess the native offering and its specified dependencies, not a hypothetical augmented system. A narrower advertised scope is not a reason to mark a criterion inapplicable, lower its requirements or excuse a P/U result. This is a common-requirements evaluation, not a vendor-claims compliance review.

This is a broad public-source inventory, not a claim to enumerate every private product, regional scheme or unpublished protocol. A source described only at overview or announcement level remains that limited evidence boundary.

1.2 Evidence scale

- **R — Full-Range architectural coverage:** reviewed architecture supplies the artifacts, bindings, verifier/enforcement rules and applicable state transitions needed for the whole criterion.
  “R” requires a mechanism supporting the whole criterion, not merely normative wording. It is not a new obligation imposed by this RFC. Any optional implementation acceptance tests below are separate from architectural ratings.
- **P — Partial:** a concrete mechanism establishes a narrower part of the criterion; the unestablished remainder must be identified.
- **U — Unestablished:** the reviewed evidence does not establish the property.

R/P/U are coverage results only. An advertised feature, optional extension label or roadmap item without a traced mechanism is U. Optionality is explained in prose where an actual mechanism is evidenced; a merely possible future composition earns no credit. The assessment stops at what the reviewed architecture establishes. It does not evaluate possibility, impossibility or implementation maturity. R is not a passing implementation test. A normative MUST without supporting mechanics is insufficient. All candidates receive the same criteria; there are no claim-based exemptions and no aggregate score.

For every row, trace the native artifact, who authenticates it, what it binds, where the action can be denied, and which state governs later use. Credit specified dependencies but not hypothetical added controls. GAuth is an explicit dependency of the assessed G-Commerce profile, not an optional advantage silently added to its row. Third-party CCPE cookbooks are compositions assessed separately from native mechanisms.

1.3 Distinguish three questions

1. **Architecture:** Are principal authority and payment/platform permission independently verifiable and enforced? This RFC evaluates architecture.
2. **Exact conformance:** Does an implementation satisfy the specific normative profile, interfaces, artefacts and audit contract? Conformance of the recommended CCPE integration profiles is subject to RFC 0170.
3. **Intellectual-property provenance and rights:** What is the provenance of the evaluated concepts and specifications, and which attribution obligations, copyright and patent rights, and licence terms apply to their implementation and use? These questions are separate from architectural coverage and normative conformance. This RFC does not determine them; neither a positive architectural assessment nor technical conformance constitutes intellectual-property clearance or resolves applicable rights and obligations.

2. Terminology and scenario test

Principal-origin authority: A delegation traceable to a concrete acting person. Where that person represents a company, the represented entity and the basis and limits of representation must be established separately from the person's identity. An account name or valid signature alone does not prove representative capacity.

Authority service: Issues and manages credentials under the principal's authorization. A service signature is not a substitute for evidence that the principal authorized issuance.

Payment permission: Authorization to use an instrument or process a transaction. **Commerce permission:** The merchant/runtime's acceptance of the proposed action. Neither creates authority the principal did not delegate.

Independent verification: Distinct evidence, decision semantics and lifecycle state can be verified without accepting a payment/platform approval as the authority verdict. Separate servers are not sufficient; shared transport is not sufficient to disprove separation.

S1 — native payment/platform control only: The assessed architecture operates payment credentials and platform rules without a distinct principal-origin authority layer. A U evidence result alone does not establish this structural diagnosis.

S2 — separate authority and platform/payment enforcement: A principal-origin authority artefact is evaluated independently before commerce permission; a denial cannot be overridden downstream (RFC 0170). Exact CCPE-F conformance additionally requires the RFC 0170 contract.

S3 — merged authority shortcut: Principal-authority claims are added to payment/identity artefacts and treated within the same authorization/lifecycle model in place of the independent authority layer. The defining concern is semantic and operational collapse, not simply JSON field count.

Classification rule: Establish the actual actors, issuers, signed objects, verification decisions and revocation handles. Test the boundary, not the brand. A hybrid credential can contain distinguishable cryptographic evidence; multiple credentials can still depend on one collapsed authority decision.

Commerce commitment boundary: The operation at which an agent submits or accepts an order, booking, subscription or other undertaking that may create an obligation for the principal under the applicable workflow and terms. This boundary can precede payment authorization or settlement. Its identification depends on the selected interface semantics and contractual process, not merely on an endpoint name, HTTP success code or payment status.

An evaluation should identify the agent-controlled submission or acceptance operation, any subsequent counterparty acceptance, and the point beyond which withdrawal is no longer assured. Principal-authority enforcement must protect the relevant agent-controlled operation before the undertaking can be created; a later payment check is not a substitute. The assessment should record separately the order/commitment state and the payment state. Where contractual effect is unresolved, the evaluation should identify that uncertainty rather than assume that no commitment occurs before payment.

2.1 Evaluation criteria

These are the common architectural requirements used by this evaluation, not vendor-selected promises or a claim of universal industry consensus. Every main-evaluation candidate is assessed on every criterion. An evidenced narrower control earns P; the missing remainder remains a gap. The reference architecture receives no presumption of full coverage.

ID	Property assessed	Evidence needed
C1	Concrete principal and representative capacity	Person binding, represented party, evidence of capacity and scope; identity alone is partial
C2	Discrete delegation	Explicit consent bound to exact delegated content and agent key
C3	Independent authority decision	Separate authority/payment evidence and decisions; downstream cannot override denial
C4	Multi-hop narrowing	Every delegate's action stays within every relevant ancestor's scope
C5	Current ancestor state	Defined freshness bounds and rejection when validity cannot be established
C6	Independent revocation lifecycle	Authority withdrawal propagates to descendants and in-flight actions within declared bounds
C7	Shared spending	Cross-agent/common-ancestor accounting; atomic reservation, replay and concurrency behavior
C8	Portability	Verifiable authority across counterparties without substituting platform trust for delegation
C9	Attribution and audit	Action, principal, delegation, both decisions and outcome can be correlated

These criteria assess coverage of a principal-authority and lifecycle requirements profile for delegated agent commerce, including organizational and multi-agent scenarios. They are not a universal product-quality ranking or a claim that every payment use case requires every property. A narrower mechanism can be suitable for its intended use while providing only partial coverage of this profile.

3. Landscape and cross-solution assessment

3.1 Protocols and specifications

Mechanism / custodian	Reviewed availability and layer	Authority assessment
AP2 / Google-origin repository; FIDO contribution process	Public v0.2 specification; payment authorization within a commerce protocol [A1,F1]	Explicit delegated authority and verification; the reviewed architecture does not establish full independent authority-

Mechanism / custodian	**Reviewed availability and layer**	**Authority assessment**
		lifecycle coverage, including ancestor-state freshness and cascading revocation
ACP / OpenAI and Stripe	Public open commerce specification; checkout and credential relay [B1]	Native checkout/payment controls established; a portable principal-origin multi-hop chain is U in reviewed introduction
UCP / industry co-development, public repository	Public evolving commerce protocol; discovery, checkout and extensions; lodging draft separately labelled [B2]	Orchestration layer; AP2 support is not itself a G-Commerce authority verdict
x402 / public ecosystem, Coinbase implementation documentation	HTTP payment-resource exchange; CDP facilitator verifies and settles [B3]	Payment proof establishes paid access, not automatically the payer-agent's upstream authority
MPP / Stripe and Tempo	Open machine payment protocol; practical protocol documentation and Stripe Frontier integration [B4]	Challenge, payment credential, receipt, replay/idempotency controls; independent representative-capacity chain U
Visa Trusted Agent Protocol	Public developer protocol and sample code; Visa-approved agent recognition [B5]	RFC 9421 signatures, agent intent and consumer/payment signatures; not proof of a full independently revocable PoA chain
Mastercard Verifiable Intent (VI)	Mastercard-maintained open draft v0.1, commit-pinned [B6]	Explicit user/agent cryptographic layering; VI-layer revocation deferred; cannot be dismissed as identity-only
Skyfire KYAPay	Public token model/example APIs; README says full v1.0 forthcoming [B7]	KYA, Pay and combined KYAPay JWTs; combined identity/payment is not enough to infer a merged PoA model
OKX Agent Payments Protocol (APP)	First-party public overview and linked developer specification; payment SDK/wallet context [B8]	Advertises agent payments, session keys and batching; escrow marked coming soon

Mechanism / custodian	Reviewed availability and layer	Authority assessment
		despite broader marketing examples; full authority contract U

3.2 Agent-commerce services and use-case profiles

Offering	Documented scope	Boundary of this evaluation
Mastercard Agent Pay / Agent Pay for Machines	Network/payment initiative, machine transaction controls and multi-rail ecosystem [B9]	Product announcement, not equivalent to the VI specification. Do not infer network enforcement detail from partner quotes
PayPal Agent Ready / Store Sync	Payment acceptance across AI channels; catalogue/cart/post-purchase orchestration [B10]	Real payment service; representative delegation, independent verdicts and cascade not established by reviewed product page
Nevermined	Catalog via x402/MPP; plans, access tokens, credits and fiat/crypto payment integration [B11]	Documented metering/access/payment layer, including card delegation; common-principal multi-hop lifecycle not established
Stripe MPP integration	PaymentIntents, shared payment tokens and stablecoin acceptance; Frontier label [B4]	Provider implementation of MPP, not a separate general authority protocol
s-you / EUDIPal Scoped Mandate, with Sparkasse requirements	Contract v2 dated 17 October; documented mock implementation, simulated SCT Inst settlement; EUDI/PaSO/SPAA context [S1–S3]	User-signed checkout scope, bank-side attestation verification, replay checks and a documented PaSO consent flow; the reviewed architecture does not establish full ancestor-state freshness, cascading authority revocation or atomic shared-budget accounting across agents.

Context, not omissions disguised as competitors: MCP/A2A are agent communication substrates; payment extensions must be assessed separately. W3C Payment Request, Open Banking/PSD2 and conventional card/SEPA rails provide

payment interfaces or regulated payment services, not automatically a cross-agent principal-authority model. RFC 0170's existing Stripe, Shopify, Amazon Pay, Open Banking and Payment Request cookbooks remain integration context, not evidence of universal adapter availability.

3.3 Compact comparative matrix

Rows assess the reviewed architectural boundary against all nine common requirements. The opening table groups related offerings; this matrix expands their models without changing the standard. Claims without mechanism evidence are U, not a separate positive coverage category.

Boundary	C1	C2	C3	C4	C5	C6	C7	C8	C9
AP2 User Credential	P	R	P	P	U	U	P	P	P
AP2 Trusted Agent Provider	P	R	U	P	U	U	P	P	P
ACP introduction	U	P	U	U	U	U	U	P	P
UCP overview	P	U	U	U	U	U	U	P	P
x402 paid-resource flow	U	U	U	U	U	U	U	P	P
MPP core overview	U	P	U	U	U	U	P	P	P
Stripe MPP integration	P	P	U	U	U	P	P	P	P
Visa TAP overview	P	P	U	U	U	U	U	P	P
VI draft v0.1	P	R	P	P	U	U	P	P	P
KYAPay token model	P	P	U	U	U	U	P	P	P
OKX APP overview	U	U	U	U	U	U	U	U	U
Mastercard Machines announcement	U	U	U	U	U	U	U	U	U
PayPal Agent Ready page	U	U	U	U	U	U	U	U	U
Nevermined documented flows	P	P	U	U	U	U	P	P	P
s-you contract v2 / documented PoC	P	R	P	U	U	P	P	P	P
GAuth + G-Commerce architecture	R	R	R	R	R	R	R	R	R

AP2 C4 P means explicit open-to-closed constraints, not a specified arbitrary organizational delegation hierarchy. AP2 C7 P recognizes cumulative budgets, not a specified shared cross-agent reservation/recovery ledger. VI C4 P recognizes user-to-

agent layered delegation; its v0.1 mandate pair is single-transaction, with multi-transaction extensions discussed rather than assumed part of that baseline. G-Commerce's full ratings rely on the inherited-core and commerce mechanism trace in §7.

C8 assesses technical portability only. It is not a rating of cross-border legal recognition, EUDI Wallet compatibility or relying-party protection. Those require the additional deployment evidence in §6.1. None of the rows - including G-Commerce - has been established by this review to meet that complete cross-border test. No protocol rating is upgraded merely because its signatures can be verified abroad.

3.4 Coverage of RFC 0170 integration surfaces

RFC 0170 is an integration specification; its cookbook roster is not the selection rule for this evaluation. AP2 (Appendix F) and s-you (Appendix G) remain main-evaluation candidates. The traditional interfaces in Appendices A–E move to this RFC's Appendix D, together with Apple Pay, Google Pay and the selected eBay marketplace interface. Appendix D.1 preserves the full crosswalk.

UCP, the §4 substrate of RFC 0170, is also positioned for agent commerce and is evaluated here on that basis. Mastercard VI/Agent Pay for Machines, Visa TAP and PayPal Agent Ready/Store Sync remain specifically identified agent-commerce offerings, not proxies for their entire companies. The distinction is offering-specific: Stripe PaymentIntents is a traditional substrate; Stripe's MPP integration is an agent-facing composition assessed under MPP.

CCPE-F candidacy does not establish conformance. A cookbook describes an integration, not evidence that the native vendor already implements GAuth or that the composition closes a candidate's C1–C9 gaps.

4. AP2 reference-case deep dive

4.1 Why AP2 is the reference case

AP2 exposes sufficiently detailed consent, delegation, transaction-binding and verifier roles to exercise the common framework. It is used in the proven methodological role as in RFC 0130: a detailed case through which readers can apply and challenge the criteria. This is not a claim that AP2 represents every payment mechanism, and no AP2-specific finding is inherited by another solution without its own evidence.

4.2 Reviewed specification boundary

The assessment uses the four AP2 documents A1–A4 at commit e1ea56db72a6385bce3e5c1112b3a56ce60acb43. A recorded byte comparison against the then-resolvable v0.2.0 tag, commit b4587ac1d055888a73b4b21750973cffba961793, found those four files identical. This is an edition-control observation, not authentication of historical tag immutability, first disclosure or patent priority.

4.3 Capabilities and the independent-authority question

The reviewed edition defines Checkout and Payment Mandates, open/closed forms, explicit user consent, key-bound delegation, transaction constraints and cumulative recurring budgets. Role-specific verification and signed linkage are substantive protections. They must not be reduced to authentication-only or described as absent merely because they use a different schema.

The separate question is whether principal-origin authority has independently verifiable evidence, a non-overridable decision and a current lifecycle distinct from payment/platform permission. Additional consent, delegation or budget features do not by themselves establish that separation. Historical corrections will be recorded in Appendix C rather than used as the organizing narrative.

4.4 User Credential model

The verifier trusts an issuer external to the agent to guarantee a Trusted Surface. The user approves mandate content; the delegation payload is included in key binding. The agent proves possession when binding an open mandate to a transaction. An issuer credential, user-approved delegation and agent action are distinguishable signed components. [A2]

This is stronger than a platform attaching unverifiable PoA-looking fields to an identity token. It directly weakens the universal “one merged credential/one verifier” premise. However, the reviewed documents do not require evidence of corporate representative capacity, current state of every upstream organizational mandate, independent authority revocation handles with cascade bounds, or two separately recorded authority/commerce verdicts.

Verdict: Principal-delegation architecture with partial separation; blanket S3 not established; complete S2 architectural properties not established by the reviewed evidence. To resolve a deployment, inspect actual issuer/holder trust, delegation signatures, both decision records and lifecycle state.

4.5 Trusted Agent Provider model

The provider's deterministic Trusted Surface obtains consent; the provider signs the mandate using a key the agent must not access directly. Verifiers trust the provider. AP2 expressly permits the same entity to occupy multiple roles, but requires it to perform all corresponding responsibilities. [A1,A2]

This increases dependence on provider attestations. It does not prove that the provider is the merchant, processor or principal, nor that all decisions are collapsed. **Where provider-signed payment mandates replace independently evaluated principal authority within the same authorization/lifecycle model, that deployment exhibits the S3 pattern.** To confirm that diagnosis, show the merged authorization/lifecycle object and the absence of an independent authority decision in the assessed implementation—not just the provider's name.

Consequences of the S3 pattern. Where principal authority and payment permission are collapsed into the same authorization and lifecycle model, payment-credential validity is not an independent assurance that the underlying delegation remains current. Changes to authority may therefore leave previously issued credentials usable, while withdrawal of authority cannot be managed independently of the payment credential's lifecycle. Cryptographic signatures and transaction constraints alone do not resolve this separation problem. GiFo-RFC 0170 §2.7 discusses these structural disadvantages. They apply where the S3 conditions above are established.

4.6 Seven architectural questions

1. **Mutation drift:** AP2 constrains action content, but current upstream authority-state checks are not fully prescribed. Retain the freshness gap, not "unconstrained agent."
2. **Delegation event:** Explicit consent/delegation exists. Evaluate its exact binding and assurance.
3. **Parent chain:** AP2 has verifiable open/closed chains and checkout/payment linkage. General multi-agent, multi-hop authority ancestry is a distinct test.
4. **Revocation:** Missing timed cascade is a legitimate specification-level distinction. Architectural impossibility is not demonstrated.
5. **Interoperability:** External User Credentials and provider-trust models differ. No universal vendor lock-in conclusion.
6. **Governance versus format:** Retain this distinction in both directions: signing more objects does not prove S2; co-carriage does not prove S3.

7. **Immutability:** Hashes, key binding and unchanged-claim checks are real integrity controls. They do not evidence fresh authority-state evaluation; assess that mechanism separately.

4.7 Decision and architecture-evidence checklist

The reviewed AP2 specification does not establish the complete independent principal-authority and lifecycle guarantees required for S2 conformance. Where an AP2 deployment treats its payment mandates and associated checks as a substitute for that independent authority layer, it falls within the S3 pattern. Additional consent, delegation or budget features do not, by themselves, change that classification.

The User Credential model provides stronger evidence of the user's authorization, but does not resolve the lifecycle gaps identified here: the reviewed architecture does not establish bounded ancestor-state freshness or independent cascading authority revocation. These gaps remain in both AP2 authorization models.

Assessment. The reviewed AP2 architecture does not establish the independent authority and lifecycle controls required for S2. It exhibits S3 characteristics where provider-signed payment mandates substitute for independently evaluated principal authority within the same authorization and lifecycle model. The User Credential model strengthens evidence of user authorization but does not resolve the identified ancestor-freshness and cascading-revocation gaps. It therefore does not change the S2 assessment.

5. Other mechanisms: assessment and closure needs

ACP: The reviewed specification introduction defines deterministic checkout and payment-token relay while retaining seller systems. It does not establish a portable PoA chain. A native checkout-only deployment is S1-shaped at that boundary; the protocol can be composed with other authority controls. Inspect delegated-payment constraints and actual agent consent/issuance records before extending that finding. [B1]

UCP: A commerce substrate with capabilities/extensions and AP2 support. Do not classify discovery or checkout transport as S3. Inspect which authority extension is negotiated and how its decision gates checkout completion. [B2]

x402: Facilitator verification and settlement support paid resource access. A successful payment does not identify the human who authorized the agent's task or prove representative capacity. Inspect the buyer wallet's delegation/policy layer separately; no protocol-wide S3 verdict follows. [B3]

MPP: The reviewed core includes payment challenges, request binding, receipts, replay protection and idempotency. Those are meaningful controls. Its payment credential is not automatically a general PoA credential. Inspect wallet authority before payment and distinguish a protocol receipt from a complete delegation audit. “MPP” here means Machine Payments Protocol, not AP2's Merchant Payment Processor role. [B4]

Visa TAP: Signed HTTP requests help recognize approved agents and protect request integrity. Consumer/payment signature surfaces merit inspection, not an assumption of identity-only capability. The overview does not establish all C1–C9 properties. Closure needs the exact consumer-consent and payment containers, signer roles and revocation behavior for the chosen onboarding model. [B5]

Mastercard VI: L1 credential, L2 user intent and L3 agent fulfilment form a meaningful cryptographic chain. The v0.1 text distinguishes immediate/autonomous modes and payment-network state for cumulative constraints. It also explicitly defers VI-layer credential revocation. It therefore provides substantive delegation evidence but not the complete G-Commerce lifecycle contract. Neither layer count nor missing revocation alone proves S3. Closure needs network enforcement traces and a defined authority-revocation design. [B6]

KYAPay: The model explicitly distinguishes identity-only KYA, payment-only Pay and combined KYAPay tokens. Identity/payment combination is not identical to PoA/payment collapse. Its sub, buyer identity and amount fields do not establish the entire C1–C9 chain. Inspect token issuance, delegated authority, lifecycle and merchant verification; do not claim full v1.0 maturity when the README says forthcoming. [B7]

APP: The OKX overview describes wallet/session-key infrastructure, HTTP 402 and payment modes. Distinguish advertised open protocol from available SDK functions; escrow is explicitly forthcoming in part of the same page. An upstream principal authority and revocation contract remains U here. Closure requires versioned protocol/security text and actual wallet enforcement, not marketing comparisons. [B8]

Network/provider offerings: Mastercard Machines, PayPal Agent Ready and Nevermined should remain in the inventory because they can supply relevant controls. Their product evidence does not justify an automatic S2/S3 decision. Inspect enrolled agent/owner attribution, spend delegation, enforcement ownership, revocation and persisted receipts for the specific service configuration. [B9–B11]

5.1 s-you / EUDIPal Scoped Mandate

Established documentary scope — contract v2. The interface dated 17 October describes one bank-held mandate with two parts: payment scope in the clear (currency, transaction/total limits, validity and merchant restrictions), and a user-signed checkout part (goods categories and exclusions) stored sealed at the bank. The wallet displays

both parts and checks their hash linkage before approval. The merchant verifies the checkout signature and goods restrictions; the bank receives the full merchant attestation and verifies its signature, mandate, checkout hash, merchant and amount, plus freshness and unused attestation identity. Payment orders remain signed by the agent's separate transport key. Direct mandate revocation and checkout-status lookup are documented. Bank and merchant remain mocks; settlement status is simulated, with no money movement. This is not evidence of a production Sparkasse rollout. [S2 §§1.2–1.14, 2.3]

Consent and trust paths. Local device authentication with posted hash/method claims remains path (a). Detailed §1.14 documents path (b), the bank as OpenID4VP/PaSO verifier: signed request, credential/key binding, audience and nonce checks, transaction-data hash verification and consent claims. Its hash covers the transmitted transaction-data entry, unlike path (a)'s canonical JSON hash. Section 1.15 additionally documents bank-issued SCA credentials through OpenID4VCI with PAR/PKCE, an authenticated mock banking session, configured issuer anchors and credential-status checks. The mock bank and demo ecosystem accept specified credential types under documented trust rules. These are substantive documented capabilities, not merely future aspirations. Wallet-side acceptance without configured roots and availability of the weaker path still require explicit production policy. Operator-issued EBW credentials remain a target; operator identity is optional under the v2 bank policy. [S2 §§1.9–1.15, 3]

Edition and implementation limits. The interface says v2 is implemented in work packages R2–R5, but warns that live builds ≤759 may retain v1 behavior. Its overview/Phase-2 table, the public overview and parts of the target page still place PaSO authorization or signed scope in the future. This review uses the detailed v2 contract for documentary requirements, records that inconsistency and does not infer which build is running. Neither the source's test claims nor deployment security were independently verified. Pin the build, authentication path, issuer/wallet trust configuration and machine-readable contract before operational reliance. The native source's “Phase 1/Phase 2” roadmap labels are not the CCPE enforcement phases. [S1–S3]

The following optional deployment checklist is not used to lower the architectural ratings. Documentary gaps are identified separately from implementation checks.

Closure question	**Current evidence and optional production acceptance requirement**
Authentic goods restrictions	V2 requires user-signed checkout scope and approval/hash linkage. Verify the selected build checks signatures and the bank-recorded hash; test expanded scope, substituted keys and stale state. Merchant live status lookup is optional, not a full ancestor-freshness guarantee.

Closure question	Current evidence and optional production acceptance requirement
Attestation-to-payment binding	V2 sends the full attestation; the bank verifies the merchant signature and mandate, checkout hash, merchant and amount, rather than accepting only agent-supplied hashes. Verify those checks at execution and the binding of the attested basket to fulfillment. Checkout-scope hash and basket hash are distinct.
Replay, retries and shared spending	V2 rejects reused attestation IDs and attestations outside the configured age bound. This is not an idempotent recovery contract for a lost payment response. Demonstrate durable replay state, atomic check/debit behavior, common-parent accounting across agents and recovery without a second charge.
Revocation and irreversible execution	Direct mandate revocation, checkout-status lookup and SCA-credential status checks are documented. Credential status at presentation does not establish automatic withdrawal of already-issued mandates. Require declared propagation bounds, descendant handling and ordering against in-flight dispatch. Completed transfers are not automatically reversed by revocation.
Principal and operator trust	Detailed PaSO verification and bank-issued credentials strengthen customer/consent evidence. Verify actual issuer anchors, wallet trust, key binding and status checks; prevent silent fallback to weaker authentication. Optional operator credentials and customer identity do not establish corporate representative capacity.
Purchase intent within permitted limits	Category and monetary limits may still permit unwanted quantities, substitutions or repeated purchases. Encode the applicable customer conditions and approval reservations; test prompt-injected but nominally in-budget orders. G-Commerce must meet the same test.

Architecture verdict. Genuine scoped authority and runtime enforcement are present in the documented design. V2 strengthens the evidence through separately signed checkout scope, consent linkage and bank-verifiable merchant attestations. The reviewed evidence still does not establish complete principal-authority-first and independent platform-decision contract, organizational ancestor checks or bounded independent lifecycle cascade.

Competitive implication. s-you is included as an agent-commerce scoped-mandate solution. Its stated plans for UCP/AP2 and external-agent integration do not themselves establish the independent authority decisions and lifecycle controls required for S2. Documented target-architecture mechanisms are assessed against C1–C9 on the same

basis as other architectural evidence; integration intentions without specified bindings, verifier rules and state transitions receive no coverage credit. The reviewed evidence does not establish the complete S2 architectural properties.

5.2 Classification and AP2 inheritance boundary

s-you is assessed as a concrete European banking/commerce use case and implementation profile under the same C1–C9 criteria as AP2 and every other main candidate. Its documented v2 flow uses its own scoped-mandate interfaces. The overview places “AP2 for external agents” and UCP merchant integration on the roadmap; the interface also notes existing UCP discovery/checkout paths from an earlier milestone. Those paths do not establish the complete v2 scoped-mandate UCP replacement or an operational AP2 bridge. Describing the PoC as an already implemented AP2 customization remains unestablished. [S1–S3]

Once AP2 is adopted, only the requirements of the selected AP2 version, authorization model and implemented flow can be inherited. Bank custody, merchant category enforcement, consent verification and operational revocation remain deployment-specific. AP2 support alone does not prove that an external agent, bank ledger and merchant share one authoritative scope, budget or lifecycle. Conversely, a deployment can add stronger controls than the protocol baseline.

5.3 Four practical cases: what can each solution handle?

The following cases explain the practical differences between AP2, s-you and GAuth + G-Commerce:

- **“Yes”** means the reviewed architecture specifies mechanisms for handling the stated situation.
- **“Partly”** means it covers only part of it.
- **“Not established”** means the reviewed architectural evidence does not support a positive conclusion.

These are architectural findings, not results of live tests. G-Commerce is assessed together with its specified GAuth dependency.

Case 1 — Enforcing shopping restrictions and spending limits

Basic scope checks and stated limits are shared capabilities; this does not establish safe enforcement of the overall allowance under concurrent purchases. Case 2 addresses that separately.

Situation. A customer authorizes purchases of groceries and household goods, excludes alcohol, and sets limits of EUR 60 per purchase and EUR 300 overall. The agent proposes a permitted EUR 25 basket, a basket containing beer, and a EUR 65 basket.

- **AP2 — Yes, for restrictions represented in the mandate.** Its delegation and constraint-checking mechanisms support rejecting purchases that exceed the authorized scope or limits. A goods restriction must be represented in the checked purchase information; a monetary limit alone does not exclude alcohol.

- **s-you — Yes.** The merchant checks the user-signed shopping restrictions. The bank verifies the merchant's attestation and checks the payment against the mandate's limits.

- **GAuth + G-Commerce — Yes.** The purchase must pass both the principal-authority check and the platform's own checks. Neither approval can override a denial by the other.

Conclusion. Basic shopping restrictions and spending limits are shared capabilities, not a distinguishing advantage of G-Commerce.

Case 2 — Preventing two agents from overspending one shared budget

Situation. Two agents share a EUR 300 allowance with EUR 50 remaining. Each simultaneously requests a EUR 40 purchase.

- **AP2 — Not established**. AP2 specifies cumulative spending constraints, but the reviewed architecture does not establish atomic reservation of a common budget across independently issued agent mandates.

- **s-you — Not established**. Its documented counters apply to a mandate bound to one agent key. They do not establish coordinated spending across several agents sharing a parent allowance.

- **GAuth + G-Commerce — Yes**. The architecture specifies shared-budget reservation and accounting. Both requests cannot consume the same remaining capacity: at most one EUR 40 purchase may proceed against the EUR 50 balance.

Conclusion. A spending limit is not enough to prevent concurrent overspending. G-Commerce specifies the shared accounting mechanism; full coverage is not established for the reviewed AP2 and s-you designs.

Case 3 — Handling a retry when the payment outcome is unknown

Situation. A EUR 25 payment is accepted, but the response is lost. The agent retries because it does not know whether the first payment succeeded.

- **AP2 — Not established**. Signed mandates and transaction links do not establish how the payment's uncertain outcome, retry and budget consumption are reconciled. The reviewed AP2 evidence does not supply the complete recovery mechanism.

- **s-you — Partly**. The bank rejects reused attestation IDs and stale attestations. This prevents replay, but does not establish how an interrupted payment is recovered with consistent payment and budget records.

- **GAuth + G-Commerce — Yes**. The architecture preserves the original operation's reservation or consumed state while its outcome remains uncertain. It specifies authenticated recovery and permits retransmission only where the executor guarantees deduplication of that same operation; otherwise, status checking or reconciliation is required.

Conclusion. Rejecting a duplicate request and safely resolving an uncertain payment are different capabilities. G-Commerce specifies both the state-preservation and recovery rules; equivalent full coverage is not established for AP2 or s-you.

Case 4 — Stopping pending purchases when authority is withdrawn

Revocation blocks actions at the protected boundary once effective within the declared bound; it does not promise cancellation of a payment already irreversibly handed off.

Situation. The customer withdraws authority after merchant approval but while the payment may still be pending.

- **AP2 — Not established**. The reviewed architecture does not establish bounded propagation of authority withdrawal through upstream and downstream delegations and affected in-flight actions.

- **s-you — Partly**. Direct mandate revocation blocks subsequent bank payments. However, the complete propagation through the delegation chain and the ordering of revocation against in-flight execution are not established.

- **GAuth + G-Commerce — Yes, within its specified revocation bounds.** Authority withdrawal propagates to affected downstream actions and platform records. Work must be blocked at the applicable execution boundary when the revocation takes effect.

Conclusion. G-Commerce specifies an independent authority-revocation lifecycle. AP2 does not establish equivalent coverage, and s-you establishes direct revocation rather than the complete mechanism.

Reading these examples: The cases demonstrate shared capabilities and shared limits. Cases 2–4 distinguish specified state/lifecycle mechanisms; any subsequent implementation checks are outside the ratings.

6. G-Commerce under the same standard

The assessed system is **GAuth's inherited authority core plus G-Commerce/CCPE-F**, not an isolated commerce envelope. The following trace uses the pinned public RFC 0170 [G3], the supplied RFC 0111 authority flow [G5], RFC 0116 interoperability contract [G6] and RFC 0117 enforcement mechanics [G7]. Each R is architectural coverage, not credit for an unsupported promise or production test.

Criterion / result	Artifact, verification and enforcement mechanism	Source and boundary
C1 — R	RFC 0111's authorization server verifies the owner's authorizer's identity and authorization (for example against a commercial register), then the client owner's identity and authorization through that authorizer, before client authorization. The commerce credential carries principal, agent, issuer and principal-evidence linkage; integrity/subject checks bind the runtime action to that credential.	G5 abstract flow I–V; G3 §3.1; G7 CHK-01/02. Corporate infrastructure supplies capacity evidence; GAuth verifies and links it rather than replacing the register. A company identifier alone would not satisfy this flow.
C2 — R	Client-owner authorization precedes issuance; the commerce mandate is principal-signed or linked to the authorized delegation actor through principal evidence. Signed structured scope, agent identity, parent reference and validity bind the grant. Integrity/holder/subject checks prevent an agent's unsigned scope copy from replacing it.	G5 flow V and request-specific grant flow; G3 §§2.7.7, 3.1, 6.2; G6 §§4–6; G7 CHK-01/02. Free-text commerce intent is expressly non-normative.

Criterion / result	Artifact, verification and enforcement mechanism	Source and boundary
C3 — R	Power-PEP evaluates the authority credential first; deny short-circuits. The distinct Commerce-PDP decision uses platform evidence. Reconciliation is deny > constrain > permit, with unresolved mandatory obligations blocking payment. Durable operation identity binds both decisions before dispatch; a successful execution response cannot retroactively supply permission.	G3 §§2.4–2.5, 3.1.3, 3.3–3.4. Logically distinct roles and evidence, not merely separate servers. For non-payment actions, the declared fail-drop-payment-only mode has a narrower fallback; payment remains fail-closed.
C4 — R	Signed child-to-parent references connect mandate → cart → payment; class-incompatible, revoked or expired parents cause denial. Child commerce/payment constraints must be subsets of parent constraints; GAuth's delegation-chain enforcement checks ordered ancestors and narrowing, not just the leaf amount.	G3 §§3.1.1–3.1.2; G7 delegation-chain check. Commerce phase classes are not permission to discard upstream organizational ancestry.
C5 — R	Reconciliation reads parent state from Authority under a default ≤5-second staleness ceiling; excess staleness becomes an unreachable-state failure. The dispatch boundary rechecks applicable authority/evidence, binding and reservation. This couples live state to the operation rather than relying solely on signature expiry.	G3 §§3.1.3–3.1.5, 2.5(c). Strict/Behörde ≤1-second profiles are reserved, not current universal guarantees. Default bounded freshness is not instantaneous consistency.
C6 — R	Authority owns a lifecycle separate from payment credentials. Cascade identifies affected platform artifacts and records withdrawal/terminal outcomes; dispatch must be blocked when invalidation is effective before handoff. Concurrent cases retain ordering evidence or remain	G3 §§3.1.3, 3.1.6, 3.2, 7.2, 7.5. Default cascade completion SHOULD be ≤5 seconds, not an unconditional MUST SLA; declare the effective bound and native cancellation limitations. No rollback of an irreversible payment is implied.

Criterion / result	Artifact, verification and enforcement mechanism	Source and boundary
	uncertain; key compromise triggers mandate-wide cascade.	
C7 — R	A durable authenticated immutable operation binds principal, agent, parents, amount/currency, payee, checkout, instrument, executor and decisions. Authoritative reservation, single-use consumption and dispatch-ready commit are atomic or equivalently safe; partial commit cannot dispatch. Uncertain outcomes retain allowance; recovery cannot create another operation or restore consumed authority. Failover, alternate routes and shared-budget ownership are explicitly inside the boundary.	G3 §3.1.3, especially Reservation/consumption, State-transition model, Recovery and Evidence/qualification. This is a specified safety protocol, not a claim that the word “budget” proves concurrency safety. Native executor deduplication limitations restrict retransmission, not the coverage rating.
C8 — R	One canonical PoA schema governs JWT/VC representations; scope checksum, issuer-key verification, holder binding, status and OAuth-engine validation contracts let independent implementations interpret and verify authority. Commerce adds canonicalized signed envelopes and UCP discovery/invocation carrying the separate authority and platform evidence.	G6 §§4–6, 10; G7 CHK-01/02; G3 §§4, 6.2. GAuth interoperability differs from a particular CCPE vendor adapter. Open alternative-substrate export work in §12(g) does not negate the credential contract. Accepted trust anchors and semantic agreements remain prerequisites, not universal legal recognition.

Criterion / result	Artifact, verification and enforcement mechanism	Source and boundary
C9 — R	Trace and mandate correlations join authority and platform decisions; the immutable operation adds reservation, consumption, dispatch ordering and authenticated executor outcome. Console persists before streaming and maintains an append-only verifiable hash chain. Outcome is distinguished from permission and uncertain state is retained rather than fabricated as success/failure.	G3 §§3.1.3, 3.3–3.4, 7.4. Attribution supports reconstruction, not automatic allocation of liability.

Conclusion: All nine criteria are covered by this combined architecture at the reviewed boundary.

Qualification of the result: RFC 0170 leaves serialized operation bindings and executor-specific status/deduplication mappings to binding profiles, while prescribing the safe state machine and invariants. That is an implementation choice within a specified mechanism, not permission to omit the mechanism. Informative cookbooks that appear to use execution as the Phase-2 verdict are subordinated by §§2.5/3.1.3 to pre-execution permission; an adapter with no such seam cannot claim conformance. C6 is full coverage of an independently bounded lifecycle, not a guaranteed five-second cancellation SLA on every rail. The same treatment applies to third parties: required dependencies and supported mechanism choices count; unspecified state transitions do not.

Native third-party rows do **not** inherit this trace merely because RFC 0170 names them in a cookbook. A composed Stripe-, AP2- or s-you-plus-GAuth system is a new assessed boundary. Its mapping must preserve both verdicts, authenticated action binding, common state ownership and the pre-dispatch stop point.

6.1 Cross-border sovereignty, recognition and accountability

The additional question: Can a supplier in another jurisdiction verify not only which company an agent represents, but who authorized it, in what capacity, for which transaction, and on what basis the supplier may rely on that authorization? The following analysis is an illustrative deployment framework, not evidence of applicable law or a finding of bilateral recognition.

Sovereignty here means retaining meaningful choice and control while transacting with others. Domestic hosting and ownership can support that aim, but do not themselves make mandates portable. Conversely, technical interoperability is necessary for automated cross-border verification but does not by itself provide legal recognition. An open credential format can still depend on a single provider's admission decisions, status service or interpretation of authority.

Three distinct layers must be checked:

1. **Technical verification and enforcement:** Is the evidence authentic, bound to this agent and transaction, within scope, current and enforced before the relevant commitment? Payment authorization alone may come too late if an agent has already placed a binding order.
2. **Trust-framework recognition:** Does the supplier accept the issuer, the evidence of the acting person's representative capacity and the meaning of the mandate's limits? Compatible schemas do not establish equivalent assurance or mutual recognition. A bridge between frameworks must not silently expand authority.
3. **Legal reliance and accountability:** What effect does the mandate have under the applicable law and contractual arrangements? What verification duties, remedies and dispute procedures apply? Technical evidence informs these questions; it does not decide them.

Additional cross-border acceptance checklist—not a new protocol certification:

Question	**Required deployment evidence**	**What this review establishes**
Can authority be interpreted consistently?	Agreed meaning of capacity, purchase versus payment powers, amount/currency, cumulative versus per-transaction ceilings, payee, expiry and delegation limits	C1–C4 cover parts of this; no bilateral semantic mapping has been validated
Can a foreign supplier trust the evidence?	Accepted issuers/trust anchors, capacity-evidence provenance, assurance requirements and explicit framework-mapping rules	Signature validity alone is insufficient; no EU–Singapore recognition finding
Can control survive different infrastructures?	Reachable status services, declared freshness bounds, common-budget enforcement and agreed handling of outages, withdrawal and provider changes	C5–C8 supply tests; no tested cross-border deployment or provider-exit guarantee

Question	Required deployment evidence	What this review establishes
What may the supplier rely on?	Agreed acceptance policy, verification obligations, transaction-bound evidence of checks and identified contractual/legal basis for reliance	A valid credential is not a universal safe harbour or promise of enforceability
Can a dispute be reconstructed and resolved?	Correlated signed decisions, timing, capacity/consent evidence, retention/access arrangements, responsible parties and dispute route	C9 supports reconstruction; applicable law, admissibility and allocation of liability remain separate review questions

G-Commerce builds on GAuth's cross-border interoperability. It inherits the common authority-credential structures, verification rules and trust-establishment mechanisms specified in GiFo-RFC 0116, particularly §§11.4–11.5. Independent GAuth instances can therefore exchange and verify delegation evidence without requiring both parties to use the same commerce platform or authorization-service operator. G-Commerce applies that interoperable authority foundation to purchases and payments. What that means in plain English:

- **Sovereignty**: Parties can operate independent GAuth implementations and retain their own authority and acceptance policies while exchanging verifiable mandates. Interoperability does not require surrendering those decisions to one commerce platform.
- **Recognition**: A receiving party can interpret and verify a foreign counterparty's delegation using common structures and semantics, subject to issuer trust. That provides the technical basis for recognizing authority across organizational and national boundaries.
- **Accountability**: GAuth's principal/delegation bindings and G-Commerce's correlated authority, payment and outcome records make it possible to reconstruct who authorized an action, within which limits, and what the receiving party accepted.

Parties retain control over their own authority services and acceptance policies; counterparties can interpret and verify delegated authority using common protocol semantics; and the authorization, transaction and outcome can be linked for accountability. The contribution is not merely a portable identity or payment credential, but interoperable evidence of who authorized an agent to act, for whom, within which limits and under which current authority state.

Legal recognition is a further layer, not a reason to discount those capabilities. The protocol supplies verifiable evidence and enforcement; applicable law and trust arrangements determine the legal effect of relying on them. Cross-instance verification

requires trusted issuers and compatible verification and status mechanisms. Whether a verified delegation legally binds an organization, and how liability is allocated, depends on applicable law and the relevant trust and contractual arrangements. These conditions qualify legal reliance; they do not negate the interoperability supplied by GAuth.

GAuth + G-Commerce provides an interoperable authority and enforcement foundation for cross-border commerce. It enables counterparties to verify delegation while preserving independent control, and supplies correlated evidence for accountability. It facilitates cross-border legal reliance without purporting to create universal legal recognition.**

Implication for AP2: AP2's verified delegation mechanisms are relevant evidence, not proof of cross-border recognition. The practical objective is independently verifiable authority plus agreed reliance rules—not a claim that one proprietary platform or one domestic infrastructure settles both.

7. Conclusions

The landscape offers meaningful but different controls. Checkout orchestration, agent authentication, cryptographic delegation, payment permission and settlement are not substitutes for one another. Evaluation must identify the concrete principal, exact delegated action, independently enforced authority and relevant commitment boundary:

- **AP2** is a useful detailed reference case because it documents substantial authorization mechanisms. The independent authority/lifecycle question remains deployment-specific: S3 applies when authority is demonstrably collapsed into payment/platform authorization; an S2 architectural finding requires affirmative evidence of independent authority and platform enforcement with the applicable lifecycle controls. Exact CCPE-F conformance additionally requires satisfaction of RFC 0170.
- **GAuth** plus G-Commerce covers C1–C9 at the architectural level through the mechanisms traced in §7. Every selected agent-commerce offering is evaluated against those same requirements. Credit comes only from the reviewed architecture's artifacts, bindings, verifier checks, enforcement and state transitions. Narrower provider claims, future extensions and hypothetical CCPE compositions do not remove gaps or establish coverage. Traditional substrates remain in Appendix D without agent-commerce scores. Implementation verification and cross-border legal reliance are separate questions for every approach.

Corrections. Corrections to architectural ratings should identify the assessed product/edition, criterion, disputed statement and mechanism-level source evidence.

Source editions and ratings can be revised without treating the reference-case choice as a commitment to a predetermined result.

Detailed criterion-level supporting analysis is available from the authors on request. Requests should identify the candidate, reviewed edition and criterion concerned; corrections supported by mechanism-level evidence will be reflected in subsequent revisions.

This RFC proposes integrating existing agent-commerce and agent-payment protocols with GAuth through the G-Commerce integration profile defined in GiFo-RFC 0170. The objective is not to replace every checkout, transaction-binding, payment or settlement mechanisms, but to combine those capabilities with independently verifiable and enforceable principal authority.

Under this approach, existing protocols retain their native commerce and payment functions. GAuth establishes and evaluates the agent's delegated authority, while G-Commerce binds that authority decision to the relevant commerce action and the downstream platform's permission. Both must permit the action: payment approval cannot substitute for principal authority or override an authority denial.

Integration must preserve more than credential compatibility. It must carry the principal and delegation bindings, enforce scope narrowing and current authority state, propagate authority revocation, coordinate shared spending and recovery, and correlate authority decisions with payment decisions and outcomes. GiFo-RFC 0170 specifies the integration requirements and provides protocol-specific cookbooks, including AP2 and s-you.

The resulting composition would combine existing commerce capabilities with GAuth's interoperable authority foundation, supporting independent control, cross-border verification of delegation and attributable transaction evidence. These properties must be established by the integrated architecture; they do not follow merely from adding GAuth fields to an existing payment credential or declaring protocol compatibility.

Protocol maintainers and service providers are invited to use the RFC 0170 profiles as a basis for concrete integration proposals. Each proposal should identify the participating components, map their responsibilities to the normative requirements, and show how the combined architecture addresses the C1–C9 findings. Coverage established by the composition must be reported separately from the native protocol assessment. Exact G-Commerce conformance remains subject to RFC 0170; intellectual-property and licensing questions remain separate.

* * *

Appendix A — Worked integration and cross-border examples

These informative examples demonstrate the evaluation method. RFC 0170 Appendices F and G remain the integration cookbooks; this appendix neither replaces them nor creates a new normative wire contract.

A.1 Scenario and actors

A person acting as a company's authorized procurement representative delegates a EUR 100,000 purchasing ceiling. An agent delegates a EUR 2,000 task to a specialist subagent. A proposed EUR 1,250 payment is within both limits only if remaining common budget, scope, validity and current authority also permit it. These are illustrative values, not profile defaults.

```
Acting person + evidence of representative capacity
| explicit, content-bound delegation
v
Authority service ---- principal-origin PoA chain
| |
v v
Agent -> subagent -> Commerce-Runtime / Power-PEP
| Phase 1: authority verdict
| deny -> stop + persist evidence
v
UCP Gimel capability / Commerce-PDP
| Phase 2: commerce verdict
v
reconcile + enforce obligations
|
AP2 credential/merchant/processor flow
|
outcome and correlated signed receipts
```

AP2 Trusted Surface -> user/provider-signed AP2 mandates

These remain distinct from the principal-origin PoA chain.

Console receives lifecycle/decision/outcome audit evidence.

Logical separation does not mean bypassing AP2 verification. Every AP2 role still performs its specified verification. Phase 2 evaluation must not itself irreversibly charge before reconciliation.

A.2 Baseline versus additions

Surface	AP2 baseline	Integration addition / prerequisite
User approval	Trusted Surface and explicit mandate content	Establish acting person, represented entity and capacity evidence at PoA issuance
Transaction authorization	Checkout/Payment mandates and receipts	Bind separate PoA chain to same action, amount, payee and transaction digest
Enforcement	Role-specific deterministic verification	Power-PEP first; UCP Commerce-PDP second; enforce final obligations before dispatch
Lifecycle	Management guidance and expiry	Fresh ancestor state, independent revocation handles, cascade and target cancellation
Budgets	AP2 recurring cumulative constraints	Shared ancestor reservation across agents, idempotent commit/release and reconciliation
Audit	Signed AP2 receipts	Correlate principal delegation, authority verdict, commerce verdict and payment outcome

A.3 Integration sequence

1. Verify the principal's identity and, where applicable, representative capacity; capture consent to exact scope. Issue the PoA chain through Authority. Do not infer company authority from possession of a corporate card.
2. Issue narrowed child credentials only within every ancestor's limits. Keep issuing and enforcing responsibilities logically distinct.

3. Obtain AP2 mandates through its Trusted Surface flow. Preserve original signed serializations; do not rewrite AP2 signatures to insert Gimel fields.
4. Construct a canonical action binding: trace identifier, nonce/idempotency key, checkout digest, amount/currency, payee and PoA identifiers. Reject mismatched identities or transactions between the two evidence sets.
5. Run Phase 1, including scope, ancestor validity and remaining budget. Atomically reserve shared spending before authorizing competing dispatches. This reservation design is an integration requirement, not a claim that the reviewed RFC supplies a proven ledger implementation.
6. Only on permit or satisfiable constrain, invoke the RFC 0170 UCP capability and evaluate Phase 2. Reconcile both verdicts; enforce obligations. A changed amount/payee/action requires reevaluation, not reuse of an old permit.
7. After both decisions have been reconciled and mandatory obligations satisfied, durably bind the decisions, authoritative reservation and single-use mandate consumption to the immutable operation in the dispatch-ready state, following RFC 0170 §3.1.3. This transition must be atomic or use the recoverably equivalent mechanism permitted by that section; a partial transition must not permit dispatch. Recheck applicable authority, freshness and operation binding at the protected dispatch boundary.
8. Dispatch and recover only that bound operation. While its outcome is uncertain, retain the applicable budget protection and consumed-mandate state. Use authenticated status or outcome evidence to settle or release the reservation. Releasing a reservation does not restore a consumed mandate. Retransmission is permitted only under the same-operation deduplication and authority conditions specified in RFC 0170 §3.1.3; otherwise, use status checking or reconciliation rather than initiating another payment.

A.4 Illustrative records—not normative wire schemas

The following objects are design sketches for correlation and review. Field names beyond quoted RFC interfaces are not claims about existing AP2/Gimel schemas. Identifiers are fictional; no usable signatures or payment secrets are included.

```
{
"record_type": "illustrative_principal_delegation",
"principal_person_ref": "person-demo-1",
"represented_entity_ref": "company-demo",
```

```
"capacity_evidence_ref": "verified-representation-demo",
"consent_evidence_ref": "signed-consent-demo",
"root_authority_ref": "poa-root",
"child_authority_ref": "poa-specialist",
"parent_ref": "poa-root",
"agent_key_ref": "agent-key-demo",
"limit_minor": 200000,
"currency": "EUR",
"revocation_ref": "authority-status-demo"
}
{
"record_type": "illustrative_action_binding",
"trace_id": "demo-trace",
"idempotency_key": "demo-payment-1",
"authority_chain_refs": ["poa-root", "poa-specialist"],
"ap2_checkout_digest_ref": "digest-demo",
"ap2_payment_mandate_ref": "payment-mandate-demo",
"payee_ref": "merchant-demo",
"amount_minor": 125000,
"currency": "EUR",
"phase1": {"verdict": "permit", "evidence_ref": "p1-demo"},
"phase2": {"verdict": "permit", "evidence_ref": "p2-demo"},
"reservation_ref": "reservation-demo",
"payment_receipt_ref": null
}
```


RFC 0170 §4 uses UCP capability discovery and a Phase-2 response carrying verdict, obligations, phase: "phase2", phase2.platform_evidenceand trace_id. Validate discovery against the actual target UCP version; the local profile's sample is not proof that a current target accepts it unchanged. Keep raw credentials out of ordinary logs; store sensitive audit evidence under access and retention controls.

A.5 Failure and acceptance cases

Case	Required cookbook behavior / evidence
Valid EUR 1,250 purchase	Both decisions permit; atomic reservation; matching action digest; one execution and receipt
EUR 2,500 child request	Phase 1 denies against child scope even if root/card funds suffice; no Phase 2/charge
Parent narrowed to EUR 1,000	New evaluation uses fresh state and denies; cached old child limit does not prevail
Parent revoked	Stop new dispatch; cascade to children and cancellable in-flight artefacts; record propagation acknowledgments
Ancestor stale or Authority unavailable	Do not dispatch payment when validity cannot be established; record explicit reason
Shared ceiling exhausted	Atomic reservation rejects excess even if each individual AP2 mandate passes its own cap
Concurrent last-budget requests	At most the affordable set reserves/commits; test with concurrent contenders, not sequential examples
Phase 2 denies or times out	No payment; payment-class timeout follows RFC fail disposition; record failure
Constraints require changed purchase	Obtain applicable approvals and rebind/recheck the changed action; no silent widening
Forged receipt or mismatched checkout	Reject; keep reservation/outcome in reconciliation state until trustworthy evidence arrives
Charge outcome unknown	Query/reconcile by idempotency reference; never blindly re-charge or immediately release funds
Revocation after settlement	Record temporal ordering; invoke applicable refund/dispute process separately, not fictional retroactive cancellation

A.6 What must exist before implementation claims

Cooperating AP2 verifiers and UCP endpoint; chosen credential/trust model; verified representative-capacity process; agreed canonical action binding; Power-PEP checks; persistent atomic ledger; revocation/freshness SLA; pre-dispatch target enforcement; receipt verification; protected audit store; failure reconciliation and adversarial tests. No adapter has been built or certified by this document.

Card/token paths do not remove normal payment compliance obligations. x402, stablecoin or other Web3 variants are not silently covered by an open CCPE-F conformance claim. Review licence scope and excluded settlement semantics separately.

A.7 Berlin–Singapore worked boundary case

This illustrative case uses a hypothetical EUR 50,000 corporate purchasing mandate. A concrete person acting in verified representative capacity for a Berlin company delegates purchasing authority to an agent dealing with a Singapore supplier. For this example, assume an aggregate EUR 50,000 ceiling, no other applicable lower limit and no earlier reservations. These are explicit assumptions: an actual mandate must state whether its cap is per order, per period or cumulative, and whether taxes, shipping and conversion costs are included.

Before the supplier accepts an order—not merely before payment—the parties need an agreed issuer/capacity trust basis and a common interpretation of the mandate. The supplier's acceptance path must obtain and verify transaction-bound authority evidence, including current status and the applicable decision, rather than trust an unbound claim from the buyer's agent. A shared budget requires trustworthy reservation evidence, not disclosure of unrelated purchases. If the order is denominated in SGD, agree the EUR conversion source, time, rounding and reservation buffer; do not compare unlike currency amounts.

Event	**Required outcome in the proposed integration**
EUR 48,000 total commitment, all checks satisfied	Reserve against the common ceiling; enforce the independent authority decision and supplier acceptance policy before commitment; retain correlated order/payment evidence
EUR 52,000 total commitment	Reject under the delegated ceiling, even if the payment instrument has sufficient funds
Two agents concurrently request EUR 30,000 each	At most one may reserve under this ceiling; independently valid credentials must not permit EUR 60,000 in commitments
Issuer signature valid, but capacity evidence or framework recognition unresolved	Hold or reject automated acceptance; route to an agreed verification process, without treating uncertainty as permission
Mandate withdrawn before commitment, or status too stale to establish validity	Stop the proposed commitment under the agreed freshness policy; record what was checked and when
Supplier proceeds despite a verified limit violation, or a control is bypassed	Preserve evidence of the limit, checks, acceptance and outcome; do not conclude automatically that the supplier, representative or company alone is liable

Order acceptance, payment authorization and settlement may be separate events. Recheck authority at the relevant controlled boundaries, while recognizing that withdrawal cannot automatically cancel an already binding commitment or reverse a settled payment. A local Power-PEP alone does not prove that the foreign supplier's acceptance path is protected. This scenario is an acceptance-test design, not a tested adapter, a bilateral recognition arrangement or a German/Singapore legal opinion.

Appendix B — Sources and evidence boundaries

- **S1:** s-you overview: https://docs.s-you.me/. Initially accessed 16 October, rechecked 18 October 2026; mutable first-party description of prototype, mocks and roadmap. Its PaSO roadmap wording lags detailed S2 §1.14; not controlling evidence that the documented v2 path is absent.
- **S2:** s-you Interface Specification: https://docs.s-you.me/interfaces. Rechecked 18 October 2026; header identifies contract v2 dated 17 October. §§1.2–1.4, 1.9–1.14 and 2.3 specify two-part consent, signed checkout scope, bank-side full-attestation verification, replay/freshness controls and PaSO authorization. §1.15 documents OpenID4VCI issuance, issuer trust and credential status; §§1.5/1.12 cover mandate revocation/status. The source claims v2 implementation but warns of older builds and retains inconsistent roadmap tables. Documentary review only: no service code, live transactions, claimed test results or adversarial tests independently verified.
- **S3:** s-you target architecture: https://docs.s-you.me/zielbild. Page labelled 15 October 2026, rechecked 18 October. Mutable content includes the two-part design and bank-issued credentials, while its current/target table retains older scope/authorization descriptions. The page date is not proof that all current content existed on 15 October; do not use its older table to negate detailed v2 controls.
- **A1..A4:** AP2 specification.md, agent_authorization.md, payment_mandate.md, implementation_considerations.mdrespectively. Immutable reviewed directory: https://github.com/google-agentic-commerce/AP2/tree/e1ea56db72a6385bce3e5c1112b3a56ce60acb43/docs/ap2. Historical comparison directory: https://github.com/google-agentic-commerce/AP2/tree/b4587ac1d055888a73b4b21750973cffba961793/docs/ap2. Relevant headings: Roles/Mandates/Modes; Mandate Delegation/Verification and Processing Rules; Budget/Agent Recurrence; Agent Key/Mandate Management.
- **F1:** FIDO contribution announcement, 28 April 2026: https://fidoalliance.org/fido-alliance-to-develop-standards-for-trusted-ai-agent-interactions/. Evidence of standards work/contributions, not completion of a repository migration or Gimel rights clearance.
- **B1:** ACP introduction and project page: https://www.agenticcommerce.dev/docs and https://www.agenticcommerce.dev/. “securely relay credentials”; names OpenAI/Stripe and merchant retention. Mutable, no release number asserted.

- **B2:** UCP overview: https://ucp.dev/. Public repository https://github.com/Universal-Commerce-Protocol/ucp. “Open and extensible”; AP2 support and commerce lifecycle. Mutable overview, not a pinned conformance profile.
- **B3:** Coinbase x402: https://docs.cdp.coinbase.com/x402/welcome. “verifies and settles payments”; confirms payment-resource role, not principal-authority equivalence. Mutable implementation docs.
- **B4:** MPP https://mpp.dev/protocol/ (page labels last update 1 October 2026) and https://docs.stripe.com/payments/machine/mpp. “single-use proof semantics”; Stripe integration labelled Frontier. Protocol overview links an IETF draft, not an issued IETF standard.
- **B5:** Visa TAP https://developer.visa.com/capabilities/trusted-agent-protocol/overview. “recognize and transact with Visa-approved AI agents”; HTTP signature standard and sample repository. Public overview, onboarding-specific detail not fully reviewed.
- **B6:** VI v0.1: https://github.com/agent-intent/verifiable-intent/blob/356c29635f1c44df7de02edb58699ca9f29bece6/spec/README.md. Definitions/Layered Credential Architecture/Threats: “VI-layer credential revocation deferred to future version.” Network-enforced constraints require cumulative state; future multi-transaction pair extension is not current blanket capability.
- **B7:** KYAPay: https://github.com/skyfire-xyz/kyapay/blob/35da6dab9626dad68bdd868f28facf8abb7f9059/docs/data-model.md. README at same commit describes forthcoming full v1.0. Token model defines KYA, Pay and KYAPay separately.
- **B8:** OKX APP overview: https://www.okx.com/en-eu/learn/agent-payments-protocol. First-party announcement; “escrow (coming soon).” Linked developer specification was not deeply audited. Advertised properties without reviewed mechanism evidence receive U; the announcement supports candidate inclusion, not coverage.
- **B9:** Mastercard Machines, June 2026: https://www.mastercard.com/global/en/news-and-trends/press/2026/june/mastercard-launches-agent-pay-for-machines.html. First-party announcement of machine payment initiative; not a normative implementation test.
- **B10:** PayPal: https://www.paypal.com/us/business/ai. “Agent Ready is your payments foundation”; Store Sync is separate orchestration. Mutable product page.

- **B11:** Nevermined: https://nevermined.ai/docs/solutions/agent-to-agent-monetization. Catalog, Embedded Web Flow and Merchant Plans; access tokens, credit balances and card delegation. Mutable docs.
- **G1:** Local RFC 0130 v0.9.1 §§5–8: method only. Do not inherit provisional vendor claims or publication status.
- **G2:** Preserved GT-WP-0171 v0.3 §§2–4 and references: superseded historical analysis, not independent proof about AP2.
- **G3:** RFC 0170 public working text, pinned 18 October 2026: https://github.com/Gimel-Foundation/GiFo-RFC-0170-G-Commerce-Integration-Profile/blob/5446d6d6c1a246eb8cf9e1a99484f52ff8ef9d11/GiFo-RFC-0170-G-Commerce-Integration-Profile.rst. §§2.4–2.5, 3.1–3.4, 4, 6.2 and 7 underpin the mechanism trace; Appendices A–G are informative integrations. In particular, current §3.1.3 replaces the stale reservation/recovery assessment. The commit identifies reviewed content, not historical priority. Reserved profiles are not treated as released guarantees.
- **G5:** Supplied RFC 0111, GAuth 1.0 (GiFo_RFC_0111_GAuth_1.0_1791188595959.pdf), abstract protocol flow, printed p.11, steps I–V and request-specific flow. Reviewed 18 October 2026. Explicit authorization verification links the authorizer, client owner and client, including commercial-register evidence. Local supplied edition, not an independently authenticated public release date.
- **G6:** Supplied RFC 0116, GAuth Interoperability (GiFo_RFC_0116_GAuth_Interoperability_1785684150167.pdf), §§4–6 and 10, reviewed 18 October 2026. Canonical schema, JWT/VC projections, checksum, status and engine-validation contracts. Does not imply every wallet/vendor already implements them.
- **G7:** Supplied RFC 0117, Power Enforcement Point (GiFo_RFC_0117_GAuth_PEP_1785684150167.pdf), credential-integrity, temporal/status/subject and delegation-chain checks; reviewed 18 October 2026. Supports runtime binding and rejection semantics, not a claim that a production PEP was exercised.
- **G4:** RFC 0210 historical v0.6/v0.7.1 references as cited by G2; current local v0.8.3 §3.0a/§3.1.1 consulted for comparison, not substituted for historical proof.
- **D1 — Discussion context only:** Two user-supplied screenshots of Hagen Saxowski's post about sovereignty, EUDI Wallet interoperability and a Berlin–Singapore EUR 50,000 agent mandate, reviewed 15 October 2026. No canonical post URL or exact publication date was supplied or independently verified. Used

to frame §6.1 and Appendix A.7, not as technical, legal or vendor-capability evidence. The added checklist is the evaluator's proposed deployment test; jurisdiction-specific recognition and liability have not been researched or determined here.

- **P1:** Stripe PaymentIntents guide: https://docs.stripe.com/payments/payment-intents — reviewed 17 October 2026; payment lifecycle, authentication, reuse and idempotency guidance. Not an audit of all Stripe agentic products.
- **P2:** Shopify Storefront Cart creation: https://shopify.dev/docs/api/storefront/2026-10/mutations/cartCreate — documentation returned 2026-10 as current when reviewed 17 October 2026; cart fields and checkout URL. Not a full checkout-security audit.
- **P3:** Amazon Pay Checkout Session: https://developer.amazon.com/docs/amazon-pay-api-v2/checkout-session.html — reviewed 17 October 2026; states, charge/Charge Permission transition and retention. Regional and production behavior requires the selected integration contract.
- **P4:** W3C Payment Request API: https://www.w3.org/TR/2026/CRD-payment-request-20260622/ — Candidate Recommendation Draft dated 22 June 2026, inspected through the latest-publication page on 17 October 2026. Distinguish it from the 8 September 2022 Recommendation; browser support is not inferred from publication.
- **P5:** Open Banking UK Payment Initiation API Profile v4.0: https://openbankinguk.github.io/read-write-api-site3/v4.0/profiles/payment-initiation-api-profile.html. Reviewed 18 October 2026: consent authorization, multiple authorization, consent revocation, payment state flow and idempotent consent/order sequences. Concrete UK API profile, not a legal determination about every PSD2 implementation.
- **P6:** Apple payment-token format reference: https://developer.apple.com/documentation/passkit/payment-token-format-reference (also supplied by Apple as the .md rendering). Reviewed 18 October 2026: verification steps 1–7 and EC_v1 fields. Five-minute signing-time comparison and processed-transaction-ID check are payment replay controls, not ancestor freshness.
- **P7:** Google Pay payment-data cryptography: https://developers.google.com/pay/api/web/guides/resources/payment-data-cryptography. Reviewed 18 October 2026: ECv2 signature input, intermediate-key verification, recipient binding, encrypted-message schema and

expiration checks. Mutable documentation; no broader Google product capability inferred.

- **P8:** eBay Buy Order v1 member placeOrder: https://developer.ebay.com/api-docs/buy/order_v1/resources/checkout_session/methods/placeOrder. Reviewed 18 October 2026: authorization-code scope, app/marketplace/session restrictions, session termination, warning 15006, error 15020 and purchase-order payment status. The page contains a guest-method cross-reference in its parameter prose; this evaluation uses its explicitly labelled member endpoint and authorization-code requirements, not that inconsistent link.

Appendix D — Traditional payment and checkout substrates

D.1 Purpose and placement

These traditional interfaces are retained for completeness as potential CCPE-F integration candidates, not scored as competing agent-commerce solutions. The assessed versions provide useful native payment, checkout and transaction controls. Combining them with an authority layer is a separate architectural composition; their presence in a cookbook does not establish a working or conformant adapter.

A provider may develop an agent-commerce offering using these substrates. That prospect is not architectural coverage and no roadmap is assumed here. A specifically documented agent-facing offering can enter the main evaluation on its own evidence—for example Stripe's MPP integration—without reclassifying every API from that provider.

RFC 0170 cookbook / surface	Placement in RFC 0171	Reason
Appendix A — Stripe	This appendix, D.2	PaymentIntents is the traditional payment-lifecycle interface. Agent-facing Stripe MPP is assessed separately under MPP.
Appendix B — Shopify	This appendix, D.2	The selected Storefront Cart API supplies commerce infrastructure and checkout handoff.
Appendix C — Amazon Pay	This appendix, D.2	Checkout Session and Charge Permission are native payment interfaces.
Appendix D — Open Banking / PSD2	This appendix, D.2	The selected UK PIS profile supplies bank consent and payment initiation.
Appendix E — W3C Payment Request API	This appendix, D.2	Browser API connecting merchant, payer and payment handler.
Appendix F — AP2	Main evaluation, §§4–5	Explicitly agent-facing payment/delegation protocol; all C1–C9 apply.
Appendix G — s-you / EUDIPal Scoped Mandate	Main evaluation, §6	Agent-commerce scoped-mandate use case; all C1–C9 apply.
Normative §4 — UCP substrate	Main evaluation, §4	Agent-commerce orchestration protocol, also used by RFC 0170. Its integration role does not exempt it from C1–C9.

RFC 0170 cookbook / surface	Placement in RFC 0171	Reason
Named expansion: Mastercard, Visa and PayPal	Main evaluation, §§4 and 6	Specifically selected agent-facing offerings, not brand-wide assessments.
Named expansion: Apple Pay, Google Pay and marketplace overlay	This appendix, D.3	Native payment methods and selected eBay checkout interface; not conflated with AP2 or broader vendor portfolios.

D.2 Native mechanisms and integration boundaries

The third column states the work of an added authority composition, not a competitive deficiency or a promise that the vendor already supplies it. This appendix assigns no C1–C9 ratings.

Selected substrate	Reviewed native architecture evidence	CCPE-F integration boundary
Stripe PaymentIntents [P1]	A reusable PaymentIntent tracks authentication and payment status; the guide recommends reusing it and an idempotency key for interrupted purchases.	Bind the native intent to the independently authorized operation, amount, payee, reservation and decisions before an executing call. Native idempotency is not the common-parent accounting mechanism.
Shopify Storefront Cart, 2026-10 [P2]	Cart lines, buyer context and checkout URL carry the shopping state into checkout.	Bind authoritative purchase scope to the actual cart and protect the relevant order/checkout commitment boundary; a cart identifier alone is not an agent mandate.
Amazon Pay API v2 [P3]	Checkout Session state supports one-time/multiple charges and transition to a Charge Permission.	Keep payment permission distinct from purchasing authority; map native permission, charge and terminal states to the operation lifecycle. Separate withdrawal, capture, settlement and authority revocation.

Selected substrate	Reviewed native architecture evidence	CCPE-F integration boundary
Open Banking UK v4.0 PIS [P5]	PISP creates consent; ASPSP authenticates the PSU and authorizes the ConsentId; payment-order creation uses that consent. Fine-grained consent is distinct from coarse OAuth scopes. Multiple-authorization and idempotent consent/order sequences define account-level controls.	Bind the bank consent/order to the independently authorized action. The selected single-payment consent cannot be revoked after authorization; do not promise bank-side rollback of a settled payment. This is a concrete UK profile, not a universal assessment of PSD2 banks.
W3C Payment Request [P4]	Browser mediates merchant, payer and selected payment handler; the resulting response is payment-method-specific.	Protect the merchant/backend commitment path with independent authority and transaction binding. Inspect handler-specific execution, status and cancellation semantics separately.

D.3 Payment methods and marketplace interface

Apple Pay EC_v1 [P6]. Apple-root certificate-chain and signature checks authenticate encrypted payment data, transaction ID and optional application-data hash. The merchant selects its decryption key through publicKeyHash, checks amount/currency against the original request and checks optional order/application binding. Signing-time comparison and rejection of processed transaction IDs address payment replay. These are native token-verification controls. An authority composition must link the verified payment to the independently authorized action; device/card authentication is not corporate representative-capacity evidence.

Google Pay ECv2 [P7]. Google root and intermediate-key verification authenticate a signed encrypted payload. Signature input binds recipient_id to merchant:merchantId; integrators check key/message expiration and decrypt card or tokenized-card data. Message ID identifies the payload but is not, by itself, a durable deduplication or shared-budget protocol. The reviewed encrypted-message schema does not bind an order amount or agent grant. An integration must supply that authenticated action linkage rather than borrowing Apple Pay's different field semantics. This payment-method interface is not another AP2 variant.

eBay Buy Order v1 member checkout [P8]. The selected marketplace overlay combines buyer OAuth, an app/marketplace-bound checkout session and an

order/payment transition. placeOrder requires an authorization-code token with buy.order, checkout-session ID and matching marketplace header. It creates the order and terminates the session. Warning 15006 identifies an already placed order; error 15020 requires a new session after an item change. Order ID is explicitly distinct from payment success. An added authority layer must guard this executing order boundary, bind the exact checkout and preserve status/recovery evidence. The member path is assessed, not a conflation with guest checkout or every marketplace API.

D.4 Composition safeguards

RFC 0170 §§2.5/3.1.3 require pre-execution authority and permission, authenticated action binding, reservation/consumption/dispatch ordering and safe recovery. A payment response cannot retroactively supply the permission that should have preceded it. Native calls that create holds or other financial effects are not read-only preflight checks.

Any proposed binding must identify the protected commitment point, selected native statuses, idempotency retention/equality rules, cancellation limitations and recovery path. Authority invalidation before handoff must block the effect; after an irreversible handoff, revocation is not automatic rollback. An interface lacking the required enforcement seam is not made conformant merely by being a candidate.

These are integration requirements, not additional coverage credited to native candidates in the main evaluation. They preserve RFC 0170's broad integration purpose while RFC 0171 evaluates agent-commerce solutions against common architectural requirements.

Appendix E — Evaluation summary

Reading the table:

- **R** means full architectural coverage supported by a traced mechanism;
- **P** means evidenced partial coverage;
- **U** means coverage not established by the reviewed architecture evidence.

See §2.1 for exact criteria. There is no aggregate ranking or exemption based on a provider's narrower claims.

Agent-commerce candidates — common C1–C9 assessment

The selected offerings occupy different roles in agent commerce, but all are evaluated against the same requirements for an agent-commerce solution. Role labels explain architecture; they do not excuse missing coverage. Native architecture and specified dependencies are assessed without hypothetical CCPE augmentation. Related offerings are grouped for readability, with distinct findings retained rather than averaged.

Candidate / role and assessed boundary	C1–C9 in order	Evidence-based conclusion / detail
GAuth + G-Commerce	R R R R R R R R R	All nine covered at architecture level, within the declared profile and trust boundary; mechanism trace and qualifications in §7 [G3,G5–G7].
AP2 / agent-payment protocol, two authorization models	P R P/U* P U U P P P	Explicit key-bound delegation. C3 differs by authorization model; full organizational lifecycle and shared-agent accounting unestablished (§5; A1–A4).
s-you / EUDIPal / scoped-mandate use case, contract v2	P R P U U P P P P	Strong consent, attestation and replay bindings; no common-parent multi-agent state contract (§6; S1–S3).
ACP / checkout and credential relay	U P U U U U U P P	Checkout consent and relay are narrower than portable organizational authority (§4; B1).
UCP / discovery, checkout and authorization extensions	P U U U U U U P P	The reviewed overview's AP2-support statement does not itself trace a delegation mechanism in the assessed UCP flow (§4; B2).
Visa Trusted Agent Protocol / agent	P P U U U U U P P	Agent/consumer/payment signatures, not a full independent PoA chain (§4; B5).

recognition and signed intent		
Mastercard / Verifiable Intent (VI) v0.1 and Agent Pay for Machines	VI: P R P P U U P P P; Machines: U U U U U U U U U	VI supplies cryptographic delegation, with independent revocation deferred. The Machines announcement does not establish the evaluated mechanisms; no brand-wide rating (§4; B6,B9).
PayPal Agent Ready / Store Sync / payment and commerce service	U U U U U U U U U	The reviewed product page establishes positioning, not the bindings and verifier/state mechanics needed to credit C1–C9 (§4; B10).
x402 / paid-resource verification and settlement	U U U U U U U P P	Proof of payment is not proof of upstream delegation (§4; B3).
MPP / machine-payment protocol; Stripe implementation noted separately	Core: U P U U U U P P P; Stripe: P P U U U P P P P	Core challenge/credential/receipt and replay mechanics; Stripe adds native PaymentIntents/shared-token controls. Related implementation, not a second Stripe headline candidate (§4; B4,P1).
Skyfire KYAPay / KYA, Pay and combined token model	P P U U U U P P P	Identity/payment token controls; independent authority not established (§4; B7).
OKX APP / published overview, wallet/session-key claims	U U U U U U U U U	The reviewed overview does not supply sufficient mechanism evidence for C1–C9; advertised features receive no coverage credit (§4; B8).
Nevermined / plans, access tokens, credits and payment flows	P P U U U U P P P	Metering and bounded payment access; full parent lifecycle unestablished (§4; B11).

AP2 C3: P for User Credential; U for Trusted Agent Provider. The separate model rows remain in §3.3. Mastercard and MPP implementation-specific results are also expanded there; grouping does not combine their ratings.

* * *

Disclaimer: ALL DOCUMENTS AND THE INFORMATION CONTAINED THEREIN ARE PROVIDED ON AN “AS IS” BASIS AND THE CONTRIBUTOR, THE ORGANIZATION THEY REPRESENT OR ARE SPONSORED BY (IF ANY), THE GIMEL FOUNDATION, AND ANY APPLICABLE MANAGERS OF ALTERNATE DOCUMENT STREAMS, DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO ANY WARRANTY THAT THE USE OF THE INFORMATION THEREIN WILL NOT INFRINGE ANY RIGHTS OR ANY IMPLIED WARRANTIES OF MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE.

PRODUCT NAMES, TRADEMARKS, AND REGISTERED TRADEMARKS REFERENCED IN THIS DOCUMENT ARE THE PROPERTY OF THEIR RESPECTIVE OWNERS AND ARE USED FOR IDENTIFICATION PURPOSES ONLY. NO ENDORSEMENT IS IMPLIED.

* * *